

## ĐỒ ÁN CUỐI MÔN

### A. Danh sách đề tài

#### 1. Đề tài: Giả lập tấn công, phòng thủ và đánh giá lỗ hổng cơ sở dữ liệu (Database Pentesting & Active Defense)

- **Mô tả tình huống:** Một doanh nghiệp lo ngại về các lỗ hổng tiềm ẩn trong hệ thống CSDL nội bộ. Họ thuê một đội ngũ an ninh mạng để tiến hành diễn tập: một nửa đội mô phỏng các cuộc tấn công thực tế (Red Team), nửa còn lại triển khai các biện pháp giám sát, ngăn chặn và vá lỗi (Blue Team).
- **Yêu cầu chi tiết:**
  - Xây dựng môi trường có chủ ý để lại lỗ hổng (khuyến khích dùng Docker để triển khai nhanh các node MySQL/SQL Server).
  - Thực hiện thành công ít nhất 3 kịch bản tấn công: SQL Injection, leo thang đặc quyền (Privilege Escalation), và khai thác điểm yếu cấu hình.
  - Cấu hình ProxySQL để nhận diện và chặn các luồng truy vấn độc hại.
  - Thiết lập lại phân quyền trên DB, áp dụng vá lỗi và chứng minh kịch bản tấn công ban đầu đã bị vô hiệu hóa.
  - Phân công:
    - 2 Red Team: Lên kịch bản và thực hiện tấn công (thăm dò, khai thác, trích xuất dữ liệu).
    - 2 Blue Team: Theo dõi log, cấu hình ProxySQL để chặn query độc hại, thiết lập tường lửa CSDL và vá lỗi phân quyền.
    - 1 Auditor: Viết báo cáo đánh giá rủi ro và tài liệu hóa các lỗ hổng theo chuẩn (ví dụ: OWASP, CVE).

#### 2. Đề tài: Triển khai Kiến trúc Zero Trust và Bảo vệ Dữ liệu Nhạy cảm Chống Giả mạo

- **Mô tả tình huống:** Hệ thống y tế quản lý bệnh án cần đảm bảo tuyệt đối tính bảo mật và toàn vẹn. Hệ thống yêu cầu ngay cả Quản trị viên (DBA) cũng không được phép đọc nội dung bệnh án, đồng thời mọi thay đổi dữ liệu phải được lưu vết không thể tẩy xóa.

- **Yêu cầu chi tiết:**

- Triển khai mã hóa dữ liệu ở trạng thái nghỉ (TDE - Transparent Data Encryption) và quản lý khóa an toàn.
- Cấu hình Row-Level Security (RLS) để phân quyền truy cập theo từng khoa/phòng ban.
- Áp dụng tính năng mã hóa nâng cao (như Always Encrypted) hoặc Data Redaction cho các cột dữ liệu cá nhân nhạy cảm.
- Cài đặt cơ chế chống giả mạo dữ liệu (như tính năng Ledger trên SQL Server) để đảm bảo tính toàn vẹn của lịch sử thao tác.
- Phân công:
  - Sinh viên 1: Triển khai TDE và quản lý vòng đời Key (Key Management).
  - Sinh viên 2: Cấu hình Always Encrypted / Data Redaction cho các cột nhạy cảm.
  - Sinh viên 3: Thiết lập Row-Level Security (RLS) theo cấu trúc phòng ban.
  - Sinh viên 4: Triển khai tính năng Ledger/Blockchain table để đảm bảo tính toàn vẹn của lịch sử giao dịch.
  - Sinh viên 5: Phát triển ứng dụng/script backend nhỏ để tương tác và chứng minh hệ thống hoạt động đúng kịch bản.

### 3. Đề tài: Xây dựng Hệ thống Kiểm toán Tập trung và Phân tích Pháp y (Database Forensics)

- **Mô tả tình huống:** Một công ty tài chính nghi ngờ có nhân viên nội bộ truy cập trái phép nhằm đánh cắp và thay đổi dữ liệu giao dịch. Nhóm cần thiết lập hệ thống giám sát chặt chẽ từ trước và thực hiện quá trình điều tra pháp y khi sự cố xảy ra.
- **Yêu cầu chi tiết:**
  - Thiết lập Audit Policy chi tiết để theo dõi các sự kiện đăng nhập, DML, DDL trên CSDL.
  - Thu thập và đẩy log từ CSDL ra một máy chủ lưu trữ log tập trung.
  - Giả lập hành vi tấn công nội bộ (Insider Threat): xóa dữ liệu trái phép và cố tình xóa dấu vết audit tại local.

- Thực hiện phân tích pháp y thông qua Transaction Logs/Redo Logs để truy vết phiên làm việc, xác định thiệt hại và tiến hành khôi phục lại dữ liệu nguyên bản.
- Phân công:
  - Sinh viên 1 & 2: Cấu hình Auditing, thu thập log từ DB và hệ điều hành, đẩy log ra một server tập trung.
  - Sinh viên 3: Đóng vai kẻ tấn công nội bộ (thực hiện xóa dấu vết, thay đổi dữ liệu trái phép).
  - Sinh viên 4 & 5 (Forensics Team): Phân tích Redo Logs/Transaction Logs, truy xuất các phiên làm việc, khôi phục lại dữ liệu bị hỏng và viết báo cáo điều tra sự cố.

#### 4. Đề tài: Thiết kế Cụm CSDL Sẵn sàng cao (HA) Tích hợp Bảo mật Toàn diện

- **Mô tả tình huống:** Dịch vụ thương mại điện tử yêu cầu cụm CSDL (Primary - Replica) hoạt động liên tục (Availability). Quá trình đồng bộ dữ liệu giữa các node và khi xảy ra sự cố chuyển đổi (Failover) phải được bảo mật tuyệt đối, không rò rỉ dữ liệu trên đường truyền.
- **Yêu cầu chi tiết:**
  - Thiết lập cấu hình Replication (trên MySQL hoặc Oracle) với yêu cầu bắt buộc: Mọi luồng dữ liệu truyền tải phải được mã hóa qua SSL/TLS.
  - Cấu hình ProxySQL để phân tải (Read/Write Split) và ẩn danh cấu trúc mạng bên dưới.
  - Xây dựng kịch bản tự động Failover khi node Primary sập.
  - Thực hiện kiểm thử xâm nhập (sniffing) mạng trong lúc đồng bộ/failover để chứng minh dữ liệu đã được mã hóa an toàn.
  - Phân công:
    - Sinh viên 1: Cấu hình môi trường mạng và chứng chỉ SSL/TLS cho các node.
    - Sinh viên 2: Thiết lập Replication có mã hóa đường truyền.
    - Sinh viên 3: Cấu hình ProxySQL để định tuyến an toàn và chống quá tải.

- Sinh viên 4: Lên kịch bản sao lưu an toàn (Encrypted Backup) và tự động hóa khôi phục.
- Sinh viên 5: Viết kịch bản kiểm thử (Test scripts) để đánh giá tính bảo mật trong quá trình hệ thống đang Failover.

### 5. Đề tài: Thiết kế và Cấu hình Bảo mật CSDL Đa Khách hàng (Secure Multi-Tenant SaaS)

- **Mô tả tình huống:** Một nền tảng phần mềm dạng dịch vụ (SaaS) phục vụ nhiều công ty (Tenant) dùng chung một instance CSDL để tối ưu chi phí. Yêu cầu đặt ra là dữ liệu giữa các công ty phải bị cô lập hoàn toàn, và không một tenant nào có thể sử dụng cạn kiệt tài nguyên hệ thống.
- **Yêu cầu chi tiết:**
  - Thiết kế Schema theo chuẩn đa khách hàng (chung DB, chung Table nhưng phân biệt qua TenantID).
  - Triển khai Row-Level Security (RLS) hoặc Virtual Private Database (VPD) để thiết lập ranh giới dữ liệu cứng giữa các công ty.
  - Cấu hình giới hạn tài nguyên (Resource Manager/Quota) nhằm ngăn chặn tấn công từ chối dịch vụ (DoS) từ một tenant.
  - Giả lập kiểm thử ranh giới: Dùng tài khoản của Tenant A cố tình thực hiện truy vấn chéo dữ liệu của Tenant B và chứng minh hệ thống chặn thành công.
  - Phân công:
    - Sinh viên 1 & 2: Thiết kế Schema và cài đặt Row-Level Security / Virtual Private Database (Oracle VPD) để cô lập dữ liệu.
    - Sinh viên 3: Quản lý Quota, giới hạn tài nguyên (Resource Manager) để tránh tấn công DoS từ một tenant.
    - Sinh viên 4: Thiết lập hệ thống cấp phát (Provisioning) tài khoản tự động và an toàn cho tenant mới.
    - Sinh viên 5: Kiểm thử ranh giới bảo mật (cố gắng dùng tài khoản tenant A để đọc dữ liệu tenant B).

## B. Quy định sản phẩm nộp và cấu trúc báo cáo

Mỗi nhóm sinh viên bắt buộc nộp các sản phẩm sau:

1. **Mã nguồn/Script & File cấu hình Docker** (nếu có).
2. **Slide trình chiếu** (tối đa 20 slide).
3. **Tài liệu kỹ thuật (Word/PDF)** định dạng chuẩn học thuật, bao gồm các chương sau:
  - **Chương 1: Giới thiệu đề tài:** Nêu bối cảnh, mô tả tình huống, mục tiêu cần đạt được và ảnh xạ trực tiếp vào mô hình bảo mật CIA (Confidentiality, Integrity, Availability).
  - **Chương 2: Nền tảng lý thuyết:** Tóm tắt các công nghệ và cơ chế bảo mật cốt lõi được sử dụng (Mã hóa, Replication, ProxySQL, RLS...).
  - **Chương 3: Sơ đồ hệ thống & Triển khai chi tiết:** Trình bày sơ đồ kiến trúc logic/vật lý. Liệt kê chi tiết (có kèm giải thích) các bước cài đặt, các đoạn mã cấu hình, phân quyền, và khởi tạo dữ liệu mẫu.
  - **Chương 4: Đánh giá & Kiểm thử:** Trình bày các kịch bản kiểm thử (Test cases). Chụp ảnh màn hình (evidence) minh họa kết quả khi hệ thống hoạt động bình thường, khi bị tấn công, và khi các cơ chế bảo mật phát huy tác dụng.
  - **Chương 5: Kết luận:** Đánh giá mức độ hoàn thành so với mục tiêu Chương 1, chỉ ra các hạn chế của mô hình và đề xuất hướng cải tiến.

### **C. Bảng Rubric đánh giá**

Điểm tổng kết đồ án được chia làm 2 phần: **Tài liệu (4.0 điểm)** và **Demo + Hỏi đáp (6.0 điểm)**. Sinh viên phải bảo vệ độc lập để có điểm cá nhân.

| Tiêu chí                             | Nội dung chi tiết                                                                                                                                    | Điểm tối đa |
|--------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|
| <b>PHẦN 1: TÀI LIỆU (4.0 ĐIỂM)</b>   |                                                                                                                                                      |             |
| 1. Hình thức & Bố cục                | Trình bày đúng cấu trúc 5 chương, văn phong học thuật, không lỗi chú thích/chính tả, có danh mục tài liệu tham khảo và có bảng phân nhiệm công việc. | 0.5         |
| 2. Nền tảng & Thiết kế (Chương 1, 2) | Phân tích rõ ràng bối cảnh, hiểu đúng bản chất công nghệ, đối chiếu chính xác với tam giác bảo mật CIA. Vẽ sơ đồ hệ thống chuyên nghiệp.             | 1.0         |

## DBS401 – Bảo mật Cơ sở Dữ liệu

|                                              |                                                                                                                              |     |
|----------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|-----|
| 3. Chi tiết triển khai (Chương 3)            | Hướng dẫn cấu hình chi tiết, logic, rõ ràng từng bước. Script/Code chuẩn mực, có chú thích đầy đủ.                           | 1.5 |
| 4. Kiểm thử & Kết luận (Chương 4, 5)         | Xây dựng các test case bao quát được cả góc độ tấn công và phòng thủ. Bằng chứng (hình ảnh/log) minh họa rõ nét, trung thực. | 1.0 |
| <b>PHẦN 2: DEMO &amp; HỎI ĐÁP (6.0 ĐIỂM)</b> |                                                                                                                              |     |
| 5. Demo hệ thống hoạt động (Nhóm)            | Triển khai thành công môi trường trực tiếp tại lớp. Kịch bản mượt mà, hệ thống chứng minh được các yêu cầu kỹ thuật đề ra.   | 2.0 |
| 6. Đánh giá tính ứng dụng (Nhóm)             | Giải pháp có khả năng chịu lỗi tốt, đáp ứng được môi trường thực tế. Tính đồng đội trong việc phối hợp xử lý lỗi khi demo.   | 1.0 |
| 7. Kỹ năng trình bày (Cá nhân)               | Slide rõ ràng, trình bày lưu loát, đúng trọng tâm, kiểm soát tốt thời gian (15-20 phút/nhóm).                                | 1.0 |
| 8. Trả lời phản biện (Cá nhân)               | Nắm vững kiến thức chuyên môn, giải thích rõ kỹ thuật của phần mình phụ trách. Trả lời thuyết phục câu hỏi của giảng viên.   | 2.0 |

